Day37_VulnerabilityAssessment

Q1 — Fundamentals [2 Marks]

Define: Vulnerability and Vulnerability Assessment.

Vulnerability: A weakness or flaw in a system, application, or network that an attacker could potentially exploit.

Vulnerability Assessment: A systematic process of identifying, analysing, validating, and prioritizing security weaknesses in systems and applications.

Q2 — VA vs Pentest [2 Marks]

Vulnerability Assessment (VA)	Penetration Testing
Identifies potential vulnerabilities.	Attempts to safely exploit vulnerabilities
Focuses on finding and prioritizing weaknesses. Focuses on demonstrating real-world security impact.	Focuses on demonstrating real-world
Usually covers a broader range of assets.	Often focuses on selected targets and attack paths.
Generally does not require exploitation	Uses controlled exploitation with authorization

Q3 — Assessment Lifecycle [3 Marks]

Explain the sequence: Scope → Asset Discovery → Scanning → Validation → Prioritization → Reporting → Remediation → Retesting.

1. **Scope**: Define the systems, networks, and applications that are authorized for assessment.

2. **Asset Discovery**: Identify the devices, services, and applications within the scope.

3. **Scanning**: Use security tools such as Nmap to identify open ports, services, and possible vulnerabilities.

4. **Validation**: Verify findings to confirm they are genuine and identify false positives.

5. **Prioritization**: Rank vulnerabilities according to severity, exposure, and potential impact.

6. **Reporting**: Document findings, evidence, risks, and recommendations.

7. **Remediation**: Fix vulnerabilities through patches, configuration changes, or service restrictions.

8. **Retesting**: Scan or test again to confirm that the vulnerabilities have been properly fixed.

Day37_VulnerabilityAssessment

Q4 — False Positives [2 Marks]

What is a false positive? Why should scanner findings be validated?

A false positive occurs when a security scanner reports a vulnerability that does not actually exist or cannot be confirmed.

Scanner findings should be validated because automated tools may incorrectly identify software versions or report vulnerabilities that are not applicable. Validation helps prevent incorrect reports and unnecessary remediation.

Q5 — Risk Prioritization [3 Marks]

Explain why vulnerability severity alone should not determine remediation priority. Include at least four contextual factors.

Vulnerability severity alone should not determine remediation priority because the actual risk depends on the system's environment and business importance.

Important factors include:

1. Asset importance: Vulnerabilities affecting critical systems require greater attention.

2. Exposure: Internet-facing services may have greater risk than isolated internal services.

3. Exploitability: Vulnerabilities that are easier to exploit may require faster remediation.

4. Potential impact: Consider possible data loss, service disruption, or unauthorized access.

5. Existing security controls: Firewalls, access restrictions, and monitoring may reduce exposure.

Q6 — CVE & CVSS [2 Marks]

Explain CVE and CVSS at a beginner level.

- **CVE (Common Vulnerabilities and Exposures):**

  A standardized identification system that assigns unique IDs to publicly known cybersecurity vulnerabilities. For example, CVE-2021-44228.

- **CVSS (Common Vulnerability Scoring System):**

  A scoring system used to measure the severity of security vulnerabilities. Scores range from 0.0 to 10.0, with higher scores indicating greater severity.

Day37_VulnerabilityAssessment

Q7 — Practical Lab [4 Marks]

Submit the Day 37 local-VM Vulnerability Assessment: scope, Nmap evidence, minimum 3 findings, severity, remediation.

Evidences:

```
┌──(kirthikaa㉿kali)-[~]
└─$ nmap -sn 192.168.77.20
Starting Nmap 7.99 ( https://nmap.org ) at 2026-11-10 11:28 +0800
Nmap scan report for 192.168.77.20
Host is up (0.0018s latency).
MAC Address: 08:00:27:25:9F:B8 (Oracle VirtualBox virtual NIC)
Nmap done: 1 IP address (1 host up) scanned in 0.23 seconds
```

```
┌──(kirthikaa㉿kali)-[~]
└─$ nmap -sV 192.168.77.20
Starting Nmap 7.99 ( https://nmap.org ) at 2026-11-10 11:29 +0800
Nmap scan report for 192.168.77.20
Host is up (0.0025s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
53/tcp   open  domain      ISC BIND 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp  open  rpcbind     2 (RPC #100000)
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login
514/tcp  open  shell       Netkit rshd
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp open  vnc         VNC (protocol 3.3)
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:25:9F:B8 (Oracle VirtualBox virtual NIC)
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

Exposed Service	FTP	HTTP	MySQL
Product	vsftpd	Apache HTTP Server	MySQL
Version	2.3.4	2.2.8	5.0.51a-3ubuntu5
Port	Port 21	Port 80	Port 3306

Finding	Severity	Reason
FTP — Port 21	Low	Nmap banner suggests vsftpd 2.3.4, but installation and actual service identity are unconfirmed.
Apache — Port 80	Medium	Confirmed outdated Apache 2.2.8 installation with no ongoing security support.
MySQL — Port 3306	Medium	Outdated MySQL version listening on all IPv4 interfaces; specific CVE applicability remains unverified.

Finding	Recommended remediation
FTP	Identify the actual FTP daemon, remove unnecessary FTP services, or replace with a supported secure file-transfer service such as SFTP.
Apache	Upgrade Apache to a currently supported release and apply security updates.
MySQL	Upgrade MySQL to a supported release, restrict database access to trusted interfaces, and enforce strong authentication.

Q8 — Retesting [2 Marks]

Why is retesting required after remediation?

Retesting is required after remediation to confirm that the identified vulnerabilities have been successfully fixed.

It also helps ensure that:

- The applied security patches or configuration changes work correctly.

- The vulnerability is no longer detectable.

- The remediation has not introduced new security issues.